

Web Application Penetration Testing

Project 5 - Cyber Security & Ethical Hacking

CODEVEDX Internship Program

Project: Web Application Penetration Testing

Author: Sayed Ahmad Abdullah

Date: June 13, 2026

Purpose: Educational - Vulnerability Testing

1. Introduction

This project tests web applications for common security vulnerabilities following OWASP Top 10 guidelines. A deliberately vulnerable Flask web application was created containing SQL Injection, XSS, and CSRF vulnerabilities.

2. OWASP Top 10 Overview

- A03:2021 - Injection (SQL Injection)
- A07:2021 - Identification Failures (XSS)
- A01:2021 - Broken Access Control (CSRF)

3. SQL Injection Testing

3.1 Test Results

Payload	Result
' OR '1'='1	Login bypassed
admin'--	Login bypassed as admin
' UNION SELECT...	Extracted all user data
Same on /safe/login	All attacks BLOCKED

3.2 Root Cause

Vulnerable code uses f-string formatting. Safe version uses parameterized queries with ? placeholders.

3.3 Mitigation

- Use parameterized queries
- Use ORM frameworks
- Input validation and whitelisting

4. XSS Testing

4.1 Stored XSS

Payload	Result
<script>alert('XSS')</script>	Script executed
	Script executed

4.2 Reflected XSS

Search input is reflected without escaping using the |safe filter.

4.3 Mitigation

- Output encoding - escape all user input
- Content Security Policy headers
- Use frameworks that auto-escape

5. CSRF Testing

5.1 Test Results

Endpoint	Result
/csrf/profile	Email changed without token
/csrf/transfer	Money transferred without token

5.2 Mitigation

- Implement anti-CSRF tokens
- Use SameSite cookie attribute
- Require re-authentication for sensitive actions

6. Vulnerability Summary

Vulnerability	Severity
SQL Injection (Login)	CRITICAL
SQL Injection (Search)	CRITICAL
Stored XSS	HIGH
Reflected XSS	MEDIUM
CSRF (Profile)	HIGH
CSRF (Transfer)	CRITICAL
Unprotected API	MEDIUM

7. Recommendations

- Implement parameterized queries for all database operations
- Add output encoding for all user-supplied content
- Implement CSRF tokens on all state-changing forms
- Deploy Web Application Firewall
- Implement Content Security Policy
- Regular security audits

8. Conclusion

This penetration test identified 7 vulnerabilities across 3 categories. The most critical are SQL Injection and CSRF on financial operations. All vulnerabilities can be remediated using standard security practices.

9. References

- [1] OWASP Top 10 2021
- [2] OWASP Testing Guide v4
- [3] CWE-89 SQL Injection
- [4] CWE-79 XSS
- [5] CWE-352 CSRF
- [6] Flask Security Documentation
- [7] PortSwigger Web Security Academy